MINISTRY OF EDUCATION AND TRAINING

UNIVERSITY OF ECONOMICS AND FINANCE

PROJECT REPORT

WEBSITE SECURITY

Major: Information Technology

Minor: Information Security

TOPIC: APPLICATION OF NESSUS FOR NETWORK SECURITY VULNERABILITY ASSESSMENT

Course: **251.ITE1223E.B02E**

Supervisor: **Nguyen Ngoc Dai**

Student:

1. **Nguyễn Quang Dũng** **MSSV : 225054052**
2. **Đỗ Đình Hoàng** **MSSV : 225050345**
3. **Lê Thiện Nhân** **MSSV : 225053134**
4. **Vy Văn Sơn** **MSSV : 225051416**

Ho Chi Minh City, 2026

MINISTRY OF EDUCATION AND TRAINING
UNIVERSITY OF ECONOMICS AND FINANCE

PROJECT REPORT

WEBSITE SECURITY

Major: Information Technology

Minor: Information Security

TOPIC: APPLICATION OF NESSUS FOR NETWORK SECURITY VULNERABILITY ASSESSMENT

Course: **251.ITE1223E.B02E**

Supervisor: **Nguyen Ngoc Dai, MSc**

Student:

1. **Nguyễn Quang Dũng** **MSSV : 225054052**
2. **Đỗ Đình Hoàng** **MSSV : 225050345**
3. **Lê Thiện Nhân** **MSSV : 225053134**
4. **Vy Văn Sơn** **MSSV : 225051416**

Ho Chi Minh City, 2026

TABLE OF CONTENTS

LIST OF TABLE

LIST OF IMAGES

ACKNOWLEDGEMENT

We would like to express our sincere and deep gratitude to all those who have contributed and supported us during the implementation of the **Application of Nessus for Network Security Vulnerability Assessment** project. We extend our special thanks to:

We sincerely thank Mr. **Nguyen Ngoc Dai**, our supervisor, for his patience, guidance, and continuous support throughout the project. His dedication and expertise have greatly helped us overcome challenges and successfully complete the development of this system. We are truly grateful for his invaluable mentorship and encouragement.

Document sources and support tools:

We would also like to acknowledge and appreciate the documents and development tools that provided us with the necessary knowledge and resources. These materials were instrumental in implementing the functions and features of the **Application of Nessus for Network Security Vulnerability Assessment** effectively.

Finally, we extend our heartfelt thanks to everyone who contributed and supported us throughout this project. Your encouragement and assistance have enabled this system to detect intrusions, resulting in early, effective, and accurate detection, thus enhancing system security .

ABSTRACTS

In the context of increasingly sophisticated and dangerous cyber-attacks, Vulnerability Management plays a pivotal role in protecting an organization's information systems. Unpatched software vulnerabilities and misconfigurations are the leading causes of data breaches and system failures.

This project focuses on the research and application of **Tenable Nessus** to perform network security vulnerability assessments. Theoretically, the project presents fundamental concepts of network security, the Common Vulnerabilities and Exposures (CVE) system, and the Common Vulnerability Scoring System (CVSS). Experimentally, a simulated network environment was established, consisting of a workstation with Nessus installed and target machines containing vulnerabilities.

The experiment conducted scans under various scenarios (basic scan and advanced credentialed scan). The results demonstrate that Nessus is capable of accurately detecting security flaws ranging from low to critical severity. Based on the detailed reports generated by the tool, the project proposes specific remediation measures, such as applying patches, modifying configurations, and strengthening password policies, to enhance the overall security of the system.

CHƯƠNG 1: GIỚI THIỆU CHUNG

1.1. Overview Of The Topic

In this age of digital transformation, IT systems are pretty much the backbone of any business. But as networks get more complex and we connect more devices and web apps, we’ve also ended up creating way too many 'entry points' for hackers. Cyberattacks nowadays aren't just about breaking things anymore; they’re mostly about stealing data and holding it for ransom. Most of these breaches happen simply because of unpatched software or a few missed security settings. That’s why having a solid Vulnerability Assessment process isn’t just a good idea (it’s a must-have for any proactive security strategy).

There’s many platforms about Vulnerability Assessment but Nessus is one of the best platforms for every business or individual. Nessus is a platform developed by Tenable that scans for security vulnerabilities in devices, applications, operating systems, cloud services and other network resources. Originally launched as an open source tool in 1998, its enterprise edition became a commercial product in 2005. The real secret behind Nessus is its plugin system. Whenever a new CVE hits the news, Tenable's guys are right on it, cranking out a NASL script to spot the threat. With hundreds of thousands of these plugins under the hood, Nessus can sniff out just about anything (from old, unpatched software to shitty passwords or just plain bad security settings). When it scans, it basically just pokes around the target to see what’s running, then checks those findings against its massive database to show you exactly where things are falling apart.

Nessus isn’t just for your typical servers anymore. It’s evolved to cover pretty much everything, from cloud setups and virtual machines to databases and even IoT gear. It’s also a huge lifesaver for companies trying to hit those strict international standards like PCI-DSS, HIPAA, or ISO 27001. Between its deep reporting and how it uses CVSS scores to rank risks, Nessus has become a go-to for anyone serious about building a risk management process that actually works.

1.2. Reasons For Choosing The Topic

1.2.1. The Urgency of Vulnerability Management

Most cyberattacks happen for one simple reason someone left a door open that should've been patched long ago. Businesses or Individuals need to stay ahead of the curve with proactive, routine checks. That's why diving into vulnerability scanning tools isn't just an option (it's the starting point for building any serious defense).

1.2.2. The Powerful Position and Capabilities of Nessus

Nessus is a powerhouse in this field, largely thanks to its massive library of "Plugins" that get real-time updates as new threats emerge. It's incredibly versatile, capable of auditing everything from IoT gadgets and cloud setups to old-school servers. By focusing on Nessus, we're working with an industry standard (the same tool that most security pros rely on every day).

1.2.3. Real-world needs and applications in Enterprises

In the business world, regular vulnerability scans aren't just a "nice-to-have"; they're a requirement for compliance standards like ISO 27001 and PCI-DSS. This research on Nessus isn't just for academic credit; it's about gaining hands-on skills. It bridges the gap between theory and the actual security workflows used by enterprises to protect their data.

1.3. OBJECTIVES OF THE RESEARCH

1.3.1. General Objective

Nghiên cứu này nhằm mục đích đánh giá hiệu quả và khả năng ứng dụng thực tế của công cụ **Tenable Nessus** trong việc dò quét, phát hiện và đánh giá các lỗ hổng bảo mật mạng. Thông qua việc triển khai kịch bản kiểm thử trên hệ thống mục tiêu, nhóm nghiên cứu muốn làm rõ quy trình kiểm định an toàn thông tin tiêu chuẩn và đề xuất các biện pháp phòng thủ chủ động cho hệ thống ứng dụng web.

1.3.2. Specific Objectives

Thứ nhất, nhóm nghiên cứu tiến hành xây dựng và chuẩn hóa môi trường thực nghiệm đánh giá an toàn thông tin theo mô hình kiểm thử hộp đen (Black-box testing). Cụ thể, công việc bao gồm việc cài đặt và cấu hình tối ưu công cụ Tenable Nessus Essentials trên nền tảng Windows, thực hiện cập nhật đầy đủ cơ sở dữ liệu Plugins qua giao diện dòng lệnh (CLI) để đảm bảo tính toàn vẹn dữ liệu. Đồng thời, nghiên cứu thiết lập các chính sách quét nâng cao (Advanced Scan Policy) nhắm vào lớp ứng dụng, nhằm dò quét toàn diện trên hệ thống mục tiêu thực tế

Thứ hai, đề tài tập trung vào việc định lượng và phân tích chuyên sâu các lỗ hổng bảo mật đã phát hiện. Dựa trên kết quả thực thi, nhóm nghiên cứu sẽ tiến hành phân loại mức độ nghiêm trọng của các điểm yếu theo hệ thống chấm điểm tiêu chuẩn quốc tế CVSS v3.0. Trọng tâm của giai đoạn này là làm rõ cơ chế hoạt động, nguyên nhân và tác động thực tế của các lỗ hổng nguy hiểm (Critical/High) như SQL Injection, Cross-Site Scripting (XSS) và việc sử dụng các phiên bản phần mềm hết vòng đời hỗ trợ (PHP Unsupported Version), đi kèm với các bằng chứng thực nghiệm (Proof of Concept) cụ thể.

Thứ ba, dựa trên kết quả phân tích rủi ro, nghiên cứu đề xuất các phương án khắc phục và chiến lược phòng thủ phù hợp. Các kiến nghị bao gồm các giải

pháp kỹ thuật tức thời như nâng cấp nền tảng, vá lỗ hổng mã nguồn, và các biện pháp dài hạn như triển khai Tường lửa ứng dụng web (WAF) cùng quy trình phát triển bảo mật (DevSecOps), nhằm mục đích hỗ trợ quản trị viên hệ thống củng cố hàng rào bảo mật và giảm thiểu tối đa bề mặt tấn công.

1.4. PROJECT STRUCTURE

Chapter 1: Introduction: Overview of the topic, reasons for choosing this research, and specific objectives.

Chapter 2: Theoretical Basis: Core concepts of security vulnerabilities, the Vulnerability Assessment workflow, and an in-depth look at Nessus.

Chapter 3: Implementation and Experimental Results: Step-by-step setup, configuring scan scenarios, and executing scans in a Lab environment. This chapter also covers the analysis of discovered vulnerabilities and proposed remediation strategies.

Chapter 4: Conclusion: A summary of the project's achievements and a look at current limitations that need to be addressed in the future.

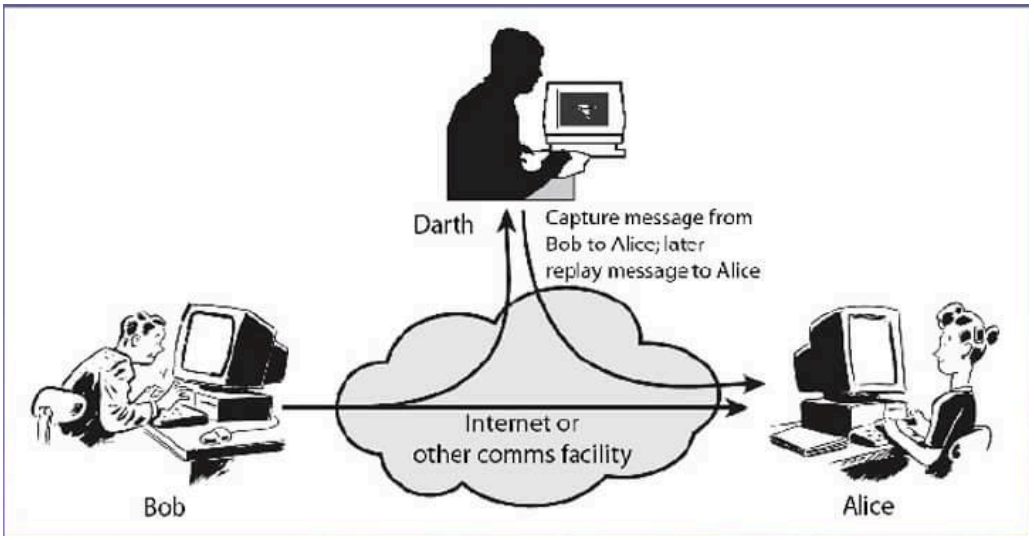
CHƯƠNG 2: THEORETICAL BASIS

2.1. Các phương thức tấn công mạng phổ biến hiện nay

2.1.1. Tấn công thụ động

Tấn công bị động hay còn gọi là tấn công bị động. Các đối tượng tấn công mạng sẽ thực hiện thu thập các mật khẩu từ email, HTTP, telnet, … đây còn được xem là cuộc tấn công chặn và nắm các hệ thống thông tin mạng cho phép hacker thực hiện các hành động mới.Tấn công thụ động sẽ làm người dùng mất dữ liệu vào trong tay kẻ tấn công mà không hề hay biết.

2.1.2. Tấn công chủ động



Tấn công chủ động là một trong các hình thức tấn công mạng tinh vi và đòi hỏi kỹ thuật cao, khá tốn kém. Tuy hiện nay đây không phải là hình thức tấn công phổ biến nhưng trong tương lai sẽ đem lại nhiều ảnh hưởng và rắc rối cho doanh nghiệp nếu không đề cao cảnh giác đối với loại tấn công này.

2.1.3. Tấn công password

Đúng như tên gọi, với cuộc tấn công này các hacker sẽ tiến hành phá mật khẩu của người dùng trên các cơ sở dữ liệu hoặc các tập tin lưu trữ. Có 3 dạng chính: brute-force attack, hybrid attack, dictionary attack

2.1.4. Tấn công từ chối dịch vụ

Đây là cuộc tấn công gây tổn hại nhiều đến khả năng trải nghiệm dịch vụ, sản phẩm của khách hàng trên website và các nền tảng khác.Hacker sẽ tổ chức thực hiện hàng loạt các truy cập bất thường vào hệ thống mạng hay trang web của doanh nghiệp nhằm làm gián đoạn hoạt động trong thời gian ngắn.

2.1.5. Tấn công theo phương pháp do thám (Reconnaissance attack

Tin tặc sẽ dùng công cụ để rà quét các lỗ hổng an ninh và kiểm tra các dịch vụ đang chạy với mục đích là thu thập thông tin về hệ thống. Hình thức này có thể được hiểu đơn giản như trước khi đột nhập vào nhà; kẻ trộm phải thăm dò, quan

sát vị trí của ngôi nhà; tìm hiểu các điểm sơ hở của chủ nhà sau đó mới bắt đầu đột nhập.

2.1.6. Tấn công mạng theo phương pháp truy cập (Access attack)

Hình thức tấn công mạng này nhằm khai thác lỗ hổng của nạn nhân. Ví dụ các lỗ hổng trong dịch vụ web, đường truyền FTP, dịch vụ xác thực… Sau khi đã thử mật khẩu bằng từ điển, hacker sẽ dễ dàng truy cập vào các tài khoản của admin trong website, cơ sở dữ liệu, phần mềm quản lý…

2.1.7. Tấn công trung gian (Man-in-the-middle attack)

Hình thức tấn công này xảy ra ngay trong lúc hai đối tượng đang giao dịch với nhau. Khi đã chen được vào giữa, chúng có thể ngay lập tức đánh cắp dữ liệu của giao dịch đó.

Nguyên nhân chính của hình thức tấn công này:

- Truy cập vào mạng di động, wifi không an toàn
- Thiết bị vô tình cài đặt phần mềm độc hại

2.1.8. Tấn Công Bằng Mã Độc Lên Hệ Điều Hành

Mã độc (malware) là một loại phần mềm được tin tặc bí mật chèn vào hệ thống nhằm mục đích xâm nhập trái phép, đánh cắp thông tin và làm gián đoạn máy tính của nạn nhân. Mã độc được phân thành nhiều loại tùy theo chức năng và cách thức lây nhiễm như: virus, rootkit, worm, trojan…

2.2. Giới thiệu công cụ Nessus

2.2.1. Nessus là gì

2.2.1.1. Khái niệm

Nessus là một công cụ quét lỗ hổng bảo mật (vulnerability scanner) do Tenable, Inc. phát triển, được thiết kế để tự động phát hiện các điểm yếu và lỗ hổng bảo mật trong hệ thống CNTT của tổ chức. Với vai trò là một giải pháp đánh giá lỗ hổng, Nessus giúp các đội ngũ an ninh mạng tìm kiếm các lỗi phần mềm, thiếu

bản vá, cấu hình sai, mã độc và những điều kiện rủi ro tiềm ẩn trong các hệ điều hành, máy chủ, thiết bị mạng và ứng dụng trước khi chúng bị khai thác bởi kẻ xấu. Khác với các công cụ tấn công hay khai thác (exploit tools), Nessus không thực hiện hack hệ thống mà tập trung vào phát hiện và đánh giá các vấn đề tồn tại.

Nessus hoạt động dựa trên một cơ sở dữ liệu plugin lỗ hổng lớn, được cập nhật thường xuyên để bắt kịp với các lỗ hổng mới được cập nhật mỗi ngày. Những plugin này chứa các bài kiểm tra xác định sự tồn tại của lỗi bảo mật (vulnerabilities) và được tải xuống tự động sau khi có thông tin mới, giúp công cụ luôn duy trì khả năng phát hiện tốt nhất.

2.2.1.2. Nhà phát triển

Nessus được phát triển và duy trì bởi công ty Tenable, Inc. Lịch sử của nó bắt đầu từ năm 1998, khi nó được Renaud Deraison phát hành dưới dạng mã nguồn mở và nhanh chóng trở nên phổ biến. Tuy nhiên, vào năm 2005, Tenable đã chuyển Nessus thành một sản phẩm thương mại và độc quyền. Sự thay đổi này cho phép Tenable tập trung tài nguyên vào việc phát triển các tính năng nâng cao, hỗ trợ khách hàng chuyên nghiệp, và xây dựng một cơ sở dữ liệu lỗ hổng (plugin) khổng lồ, được cập nhật liên tục. Ngày nay, Tenable là một công ty hàng đầu trong lĩnh vực quản lý rủi ro và lỗ hổng bảo mật, và Nessus là sản phẩm chủ lực, định hình các tiêu chuẩn của ngành.

2.2.1.3. Lý do Nessus được dùng rộng rãi và phổ biến

Nessus giữ vững vị thế dẫn đầu thị trường và được sử dụng rộng rãi trên toàn cầu nhờ vào sự kết hợp của độ chính xác, tính toàn diện, và khả năng cung cấp thông tin có thể hành động được. Lý do then chốt là công cụ này sở hữu một cơ sở dữ liệu khổng lồ và được cập nhật liên tục, cho phép nó kiểm tra hơn hàng chục nghìn lỗ hổng đã biết, bao gồm cả những lỗi cấu hình phức tạp và các lỗ hổng mới được công bố (Zero-day), đảm bảo phạm vi quét luôn ở mức cao nhất. Hơn nữa, chất lượng đầu ra là một yếu tố quyết định; báo cáo của Nessus vượt trội vì

nó không chỉ liệt kê các vấn đề mà còn cung cấp Mức độ Nghiêm trọng theo các tiêu chuẩn ngành như CVSS và quan trọng nhất là đưa ra Hướng dẫn Khắc phục (Remediation Steps) chi tiết, giúp đội ngũ bảo mật nhanh chóng xử lý các rủi ro. Cuối cùng, tính dễ sử dụng với giao diện người dùng trực quan, cấu hình linh hoạt, kết hợp với độ chính xác cao từ tính năng quét xác thực, làm cho Nessus trở thành công cụ tiêu chuẩn và không thể thiếu, giúp các tổ chức quản lý rủi ro bảo mật một cách chủ động, hiệu quả và đáng tin cậy.

2.2.2. Các phiên bản của Nessus

2.2.2.1. Nessus Essentials (Phiên bản Miễn phí)

Đây là phiên bản cơ bản và hoàn toàn miễn phí, được thiết kế cho các cá nhân, sinh viên, hoặc chuyên gia bảo mật mới bắt đầu. Mặc dù miễn phí, Nessus Essentials vẫn cung cấp đầy đủ các chức năng quét lỗ hổng chuyên sâu. Tuy nhiên, phiên bản này có giới hạn quan trọng là chỉ cho phép quét tối đa 16 địa chỉ IP. Đây là lựa chọn lý tưởng cho việc học tập, thực hành hoặc bảo mật các mạng lưới nhỏ.

2.2.2.2. Nessus Professional (Phiên bản Thương mại)

Đây là phiên bản tiêu chuẩn dành cho các chuyên gia tư vấn bảo mật độc lập, kiểm thử xâm nhập (Penetration Testers) và các doanh nghiệp vừa cần một công cụ quét lỗ hổng mạnh mẽ. Nessus Professional là phiên bản trả phí và không bị giới hạn về số lượng địa chỉ IP được quét, cho phép người dùng thực hiện các dự án tư vấn quy mô lớn. Nó cung cấp các công cụ báo cáo và tùy chỉnh quét nâng cao, cần thiết cho các công việc kiểm thử chuyên nghiệp.

2.2.2.3. Nessus Expert (Phiên bản Cao cấp)

Nessus Expert là phiên bản cao cấp nhất, dành cho các chuyên gia bảo mật cấp cao và các tổ chức có yêu cầu bảo mật phức tạp, đặc biệt trong các môi trường điện toán đám mây và ứng dụng hiện đại. Phiên bản này bao gồm tất cả các tính năng của Nessus Professional và bổ sung các khả năng quét nâng cao như Quét ứng dụng web (Web Application Scanning), Quét cơ sở hạ tầng Cloud (Cloud

Infrastructure Auditing) và Quét bề mặt tấn công bên ngoài (External Attack Surface Scanning). Nó được thiết kế để cung cấp cái nhìn toàn diện hơn về rủi ro trong các kiến trúc công nghệ phức tạp.

2.2.2.4. Nessus Manager (Phiên bản Doanh Nghiệp)

Ngoài ra, còn có phiên bản Nessus Manager, hướng tới các tổ chức lớn hoặc môi trường doanh nghiệp có nhiều scanner cần quản lý tập trung. Nessus Manager cho phép điều phối và quản lý nhiều instance Nessus từ một giao diện quản lý duy nhất, giúp đơn giản hóa việc cập nhật, phân tích và báo cáo trên quy mô rộng hơn, bao gồm cả môi trường có sử dụng agent. Việc lựa chọn một biến thể phù hợp phụ thuộc vào mức độ phức tạp của hệ thống, phạm vi quét và nhu cầu quản lý ở từng tổ chức.

2.2.3. Cách thức hoạt động

2.2.3.1. Xác định mục tiêu (Target Discovery)

Nessus hoạt động như một công cụ quét lỗ hổng bảo mật tự động, thực hiện một chuỗi các bước tuần tự để xác định những điểm yếu có thể bị kẻ xấu khai thác trong hệ thống mạng và máy chủ. Đầu tiên, Nessus tiến hành xác định mục tiêu (Target Discovery) bằng cách quét các địa chỉ IP hoặc dải mạng được chỉ định để tìm các host đang hoạt động. Công cụ này sử dụng các kỹ thuật như gửi gói ping (ICMP Echo Request) hoặc ARP scan để phát hiện máy chủ hay thiết bị đang trực tuyến, từ đó xây dựng danh sách các đối tượng cần quét.

2.2.3.2. Quét cổng và dịch vụ (Port & Service Scanning)

Sau khi danh sách mục tiêu được xác định, Nessus chuyển sang bước quét cổng và dịch vụ (Port & Service Scanning), trong đó nó quét các cổng mạng mở trên mỗi host và xác định các dịch vụ đang chạy cũng như phiên bản phần mềm tương ứng. Việc quét này thường dựa trên các kỹ thuật như *TCP SYN scan*, *UDP scan* và fingerprinting dịch vụ để phân tích các phản hồi, giúp xác định chi tiết tính chất của từng dịch vụ đang hoạt động.

2.2.3.3. Thu thập thông tin (Enumeration)

Khi các dịch vụ và cổng đã được xác định, Nessus tiến hành thu thập thông tin chi tiết (Enumeration). Ở bước này, nếu cấu hình *credentialed scan* được bật và thông tin đăng nhập hợp lệ được cung cấp, Nessus có thể đăng nhập vào hệ thống để thu thập dữ liệu nội bộ như phiên bản hệ điều hành, bản vá, cấu hình bảo mật, danh sách user nhóm quyền và thông tin log hệ thống. Nếu không có credential, Nessus vẫn có thể lấy thông tin chi tiết bằng cách tương tác với các dịch vụ mở.

2.2.3.4. Phân tích lỗ hổng (Vulnerability Detection)

Bước cốt lõi nhất gọi là phân tích lỗ hổng (Vulnerability Detection). Trong bước này, Nessus so sánh dữ liệu thu thập được với cơ sở dữ liệu plugin lỗ hổng rộng lớn (Nessus Plugin Database), trong đó mỗi plugin tương ứng một bài kiểm tra lỗ hổng cụ thể. Nessus sử dụng hệ thống plugin này để xác định những lỗi, phần mềm lỗi thời, cấu hình sai và các vấn đề rủi ro khác bằng cách đối chiếu với các lỗ hổng đã biết và các mã định danh lỗ hổng như CVE. Khi phát hiện lỗ hổng, công cụ cũng ghi lại mức độ nghiêm trọng dựa trên hệ thống như CVSS và cung cấp thông tin về biện pháp khắc phục.

2.2.3.5. Đánh giá & Báo cáo (Analysis & Reporting)

Sau khi toàn bộ quá trình quét hoàn tất, Nessus tiến hành đánh giá và báo cáo (Analysis & Reporting) kết quả. Các lỗ hổng được phân loại theo mức độ nguy hiểm như *Critical, High, Medium, Low* và *Informational*, đồng thời công cụ sinh ra các báo cáo chi tiết theo nhiều định dạng như HTML, PDF, CSV hoặc XML để người dùng dễ dàng xem xét và xử lý. Báo cáo này thường kèm theo các bước khắc phục đề xuất (remediation steps) giúp đội ngũ an ninh nhanh chóng lập kế hoạch vá lỗi và giảm thiểu rủi ro.

2.3. Các chức năng chính của Nessus

2.3.1. Phạm vi bao quát toàn diện các lỗ hổng bảo mật

Nessus có khả năng phát hiện nhiều loại lỗ hổng bảo mật khác nhau trong hệ thống, từ việc thiếu các bản vá và cập nhật phần mềm đến những lỗi cấu hình sai trong hệ điều hành, cơ sở dữ liệu và ứng dụng. Công cụ này còn kiểm tra các mật khẩu mặc định và cơ chế xác thực yếu, đồng thời quét các cổng và dịch vụ mở có thể bị tấn công từ bên ngoài. Nessus cũng nhận biết các lỗ hổng bảo mật đặc thù của ứng dụng web và giao thức mạng. Với cơ sở dữ liệu rộng lớn gồm hơn 130.000 plugin lỗ hổng, Nessus cung cấp đánh giá toàn diện về các điểm yếu tiềm ẩn trong mạng và hệ thống, giúp đội ngũ bảo mật nắm bắt và xử lý rủi ro hiệu quả hơn.

2.3.2. Quét chính xác và nhanh chóng

Nessus nổi tiếng về độ chính xác và tốc độ quét. Nó giảm thiểu các cảnh báo sai bằng cách đối chiếu các phát hiện lỗ hổng với các thông báo và bản vá lỗi đã biết từ nhà cung cấp. Điều này đảm bảo các nhóm bảo mật không lãng phí thời gian điều tra các vấn đề không tồn tại, một vấn đề thường gặp với các công cụ quét kém chính xác hơn.

2.3.3. Chính sách có thể tùy chỉnh và được xây dựng sẵn

Nessus cung cấp một số mẫu quét được xây dựng sẵn để giải quyết các trường hợp sử dụng phổ biến, chẳng hạn như quét mạng, kiểm tra ứng dụng web và quét phần mềm độc hại. Các mẫu này cho phép người dùng nhanh chóng thiết lập các bản quét mà không cần cấu hình phức tạp. Tuy nhiên, đối với người dùng nâng cao hơn, Nessus cũng cho phép tạo các chính sách quét tùy chỉnh phù hợp với môi trường và yêu cầu bảo mật cụ thể.

2.3.4. Quét có tác nhân và quét không có tác nhân

Nessus cung cấp cả hai tùy chọn quét: quét có tác nhân và quét không cần tác nhân. Với quét không cần tác nhân , Nessus quét hệ thống từ xa qua mạng. Tuy

nhiên, trong môi trường mà một số thiết bị có thể bị cô lập hoặc có kết nối mạng hạn chế, các tác nhân Nessus có thể được triển khai để thực hiện quét cục bộ và gửi kết quả trở lại bảng điều khiển Nessus.

2.3.5. Kiểm toán tuân thủ

Ngoài việc xác định các lỗ hổng, Nessus còn có thể kiểm tra hệ thống để đảm bảo tuân thủ các khung pháp lý như PCI DSS, HIPAA và NIST. Tính năng này đặc biệt hữu ích cho các tổ chức cần tuân thủ các tiêu chuẩn ngành hoặc quy định của chính phủ. Nessus tạo ra các báo cáo tuân thủ, nêu bật những khu vực mà hệ thống có thể không đáp ứng các chính sách bảo mật cần thiết, giúp các nhóm giải quyết các thiếu sót về tuân thủ.

2.3.6. Tích hợp các công cụ bảo mật khác

Nessus tích hợp với nhiều công cụ quản lý CNTT và bảo mật khác nhau. Nó có thể được sử dụng kết hợp với các hệ thống Quản lý Thông tin và Sự kiện Bảo mật (SIEM), nền tảng phản ứng sự cố và các khung bảo mật mạng khác. Sự tích hợp này đảm bảo dữ liệu về lỗ hổng được chia sẻ trong toàn tổ chức, cho phép đưa ra quyết định tốt hơn và quy trình khắc phục được hiệu quả hơn.

CHƯƠNG 3: QUÁ TRÌNH VÀ KẾT QUẢ THỰC NGHIỆM

3.1. Thiết lập môi trường thực nghiệm (Experimental Setup)

Để đánh giá khả năng phát hiện lỗ hổng của công cụ Nessus, nhóm nghiên cứu chúng em đã thiết lập một kịch bản kiểm thử hộp đen (Black-box testing) trên môi trường mạng thực tế.

3.1.1. Cấu hình máy trạm (Scanner Host)

- **Hệ điều hành:** Windows 10/11 (Localhost).
- **Phần mềm:** Tenable Nessus Essentials (Phiên bản mới nhất).
- **Cơ sở dữ liệu lỗ hổng (Plugin Set):** Đã được cập nhật đầy đủ đến thời điểm thực nghiệm thông qua giao diện dòng lệnh (CLI) để đảm bảo nhận diện được các mã khai thác (CVE) mới nhất.

3.1.2. Đối tượng kiểm thử (Target System)

- **Tên miền:** `testphp.vulnweb.com`
- **Địa chỉ IP phân giải:** `44.228.249.3`
- **Đặc điểm:** Đây là một ứng dụng web được xây dựng bởi Acunetix, cố tình chứa các lỗ hổng bảo mật phổ biến (OWASP Top 10) nhằm phục vụ mục đích nghiên cứu và đào tạo an toàn thông tin.
- **Nền tảng phát hiện:** Web Server Nginx, Ngôn ngữ lập trình PHP, Cơ sở dữ liệu MySQL.

3.2. Quy trình thực nghiệm (Methodology)

Quá trình thực nghiệm được tiến hành theo quy trình kiểm định bảo mật tiêu chuẩn gồm 3 giai đoạn:

Giai đoạn 1: Khởi tạo và Cập nhật (Initialization & Update)

Trước khi thực hiện quét, hệ thống Nessus yêu cầu cập nhật Plugins. Do kích thước cơ sở dữ liệu lớn và vấn đề tương thích dịch vụ, quá trình cập nhật được thực hiện thủ công qua nessuscli để đảm bảo tính toàn vẹn dữ liệu.

- Lệnh thực thi: nessuscli update --all
- Trạng thái: **Success** (Hoàn tất cập nhật và biên dịch Plugins).

Giai đoạn 2: Cấu hình chính sách quét (Scan Policy Configuration)

Nhóm nghiên cứu lựa chọn Template **"Web Application Tests"** (hoặc Basic Network Scan với cấu hình Web nâng cao) nhằm tập trung vào lớp ứng dụng (Layer 7).

- **Target:** Nhập trực tiếp địa chỉ IP `44.228.249.3` để loại bỏ các vấn đề liên quan đến độ trễ phân giải DNS, đảm bảo kết nối ổn định giữa Scanner và Host.
- **Discovery Mode:** Port scan (Quét cổng) toàn diện để xác định các dịch vụ đang chạy.
- **Assessment Mode:** Complex (Phức tạp) - Cho phép Nessus thực hiện các kỹ thuật fuzzing vào các trường input trên website.

Giai đoạn 3: Thực thi và Giám sát (Execution & Monitoring)

- **Thời gian bắt đầu:** 20:47 PM.
- **Thời gian hoàn thành:** 21:41 PM.
- **Tổng thời gian thực thi:** Khoảng 54 phút.
- **Trạng thái kết thúc:** Completed.

3.3. Kết quả và Phân tích (Results & Analysis)

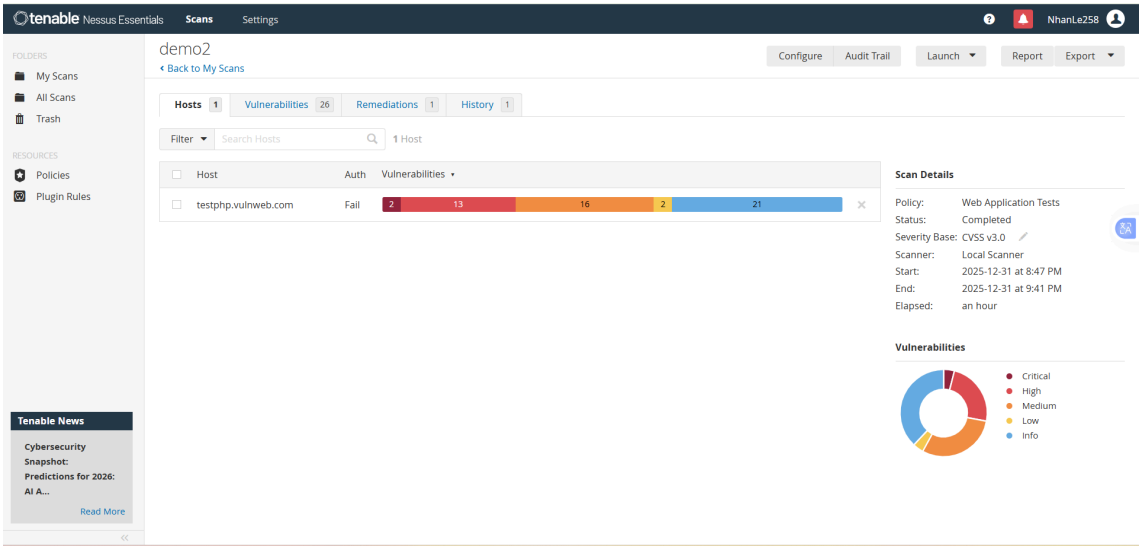
3.3.1. Thống kê định lượng (Quantitative Analysis)

Kết quả quét cho thấy hệ thống mục tiêu tồn tại nhiều điểm yếu bảo mật nghiêm trọng. Nessus phân loại các lỗ hổng dựa trên thang điểm CVSS (Common Vulnerability Scoring System) v3.0.

Bảng thống kê mức độ lỗ hổng:

Mức độ (Severity)	Số lượng	Màu hiển thị	Ý nghĩa
Critical	2	🔴 Đỏ sẫm	Rủi ro đặc biệt nghiêm trọng, có khả năng bị chiếm quyền kiểm soát hệ thống ngay lập tức.
High	13	🔴 Đỏ tươi	Rủi ro cao, ảnh hưởng trực tiếp đến tính bảo mật dữ liệu và tính toàn vẹn hệ thống.
Medium	16	🟠 Cam	Rủi ro trung bình, yêu cầu điều kiện nhất định để khai thác.
Low	2	🟡 Vàng	Rủi ro thấp, chủ yếu là lộ lọt thông tin cấu hình.
Info	21	🔵 Xanh	Thông tin trinh sát hệ thống (OS, Services).

Nhận xét: Tỷ lệ lỗ hổng ở mức độ **Critical và High** chiếm tỷ lệ đáng báo động, cho thấy hệ thống hoàn toàn không đáp ứng được các tiêu chuẩn bảo mật tối thiểu.

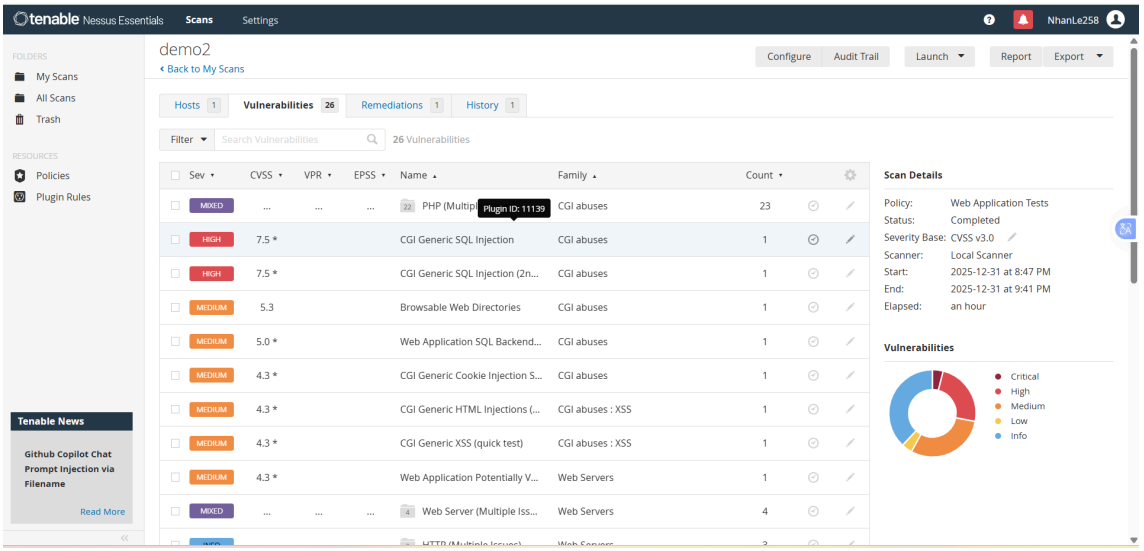


3.3.2. Phân tích chi tiết lỗ hổng điển hình (Qualitative Analysis)

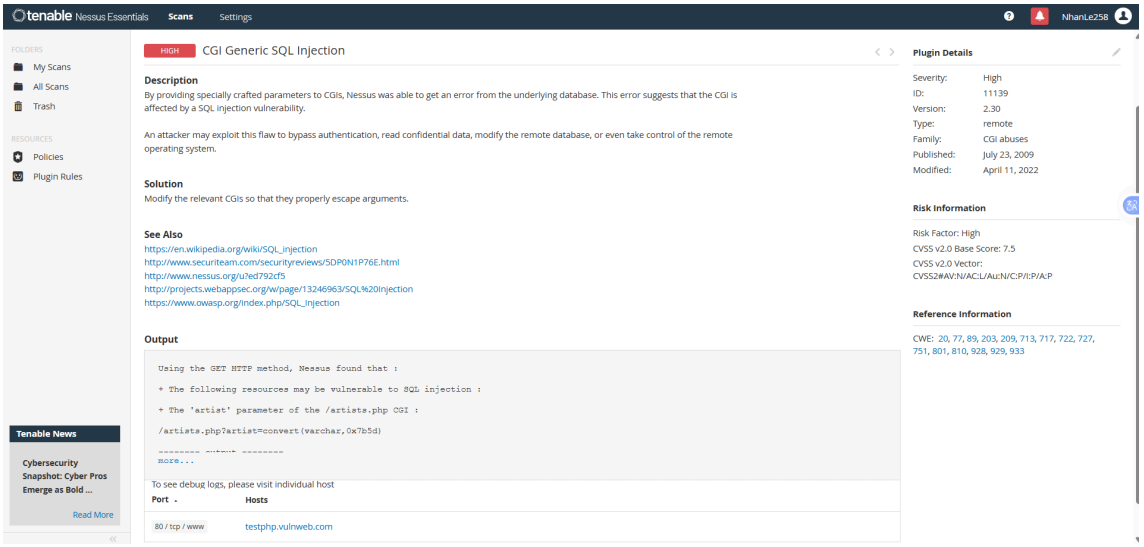
Dưới đây là phân tích sâu về các lỗ hổng nguy hiểm nhất được Nessus phát hiện, kèm theo bằng chứng thực nghiệm (Proof of Concept).

A. Lỗ hổng SQL Injection (CGI Generic SQL Injection)

- **Mức độ:** High
- **Điểm CVSS:** 7.5

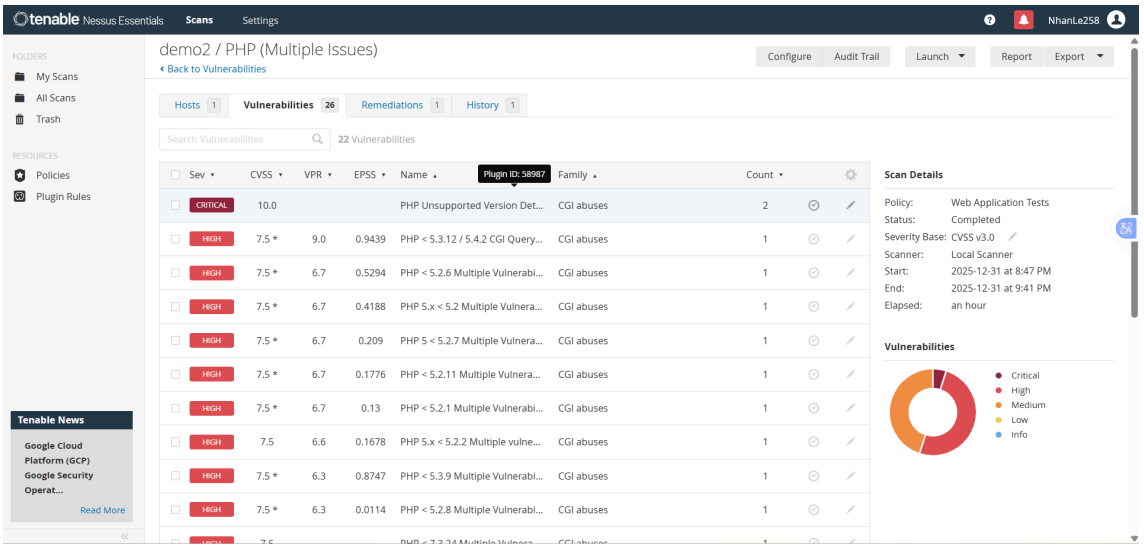


- **Mô tả kỹ thuật:** Nessus phát hiện ứng dụng web không thực hiện cơ chế lọc dữ liệu đầu vào (Input Validation) tại các tham số trên URL. Điều này cho phép kẻ tấn công chèn các đoạn mã SQL bất hợp pháp vào câu lệnh truy vấn gửi đến cơ sở dữ liệu.
- **Bằng chứng thực nghiệm (Evidence):** Nessus đã thực hiện gửi một HTTP GET Request có chứa các ký tự đặc biệt (payload test) vào tham số cat. Kết quả trả về từ máy chủ chứa thông báo lỗi cú pháp SQL hoặc có sự thay đổi bất thường về thời gian phản hồi, xác nhận lỗ hổng tồn tại.
- **Nguy cơ:** Kẻ tấn công có thể trích xuất toàn bộ dữ liệu khách hàng, thay đổi thông tin sản phẩm hoặc xóa sạch cơ sở dữ liệu (Database Drop).

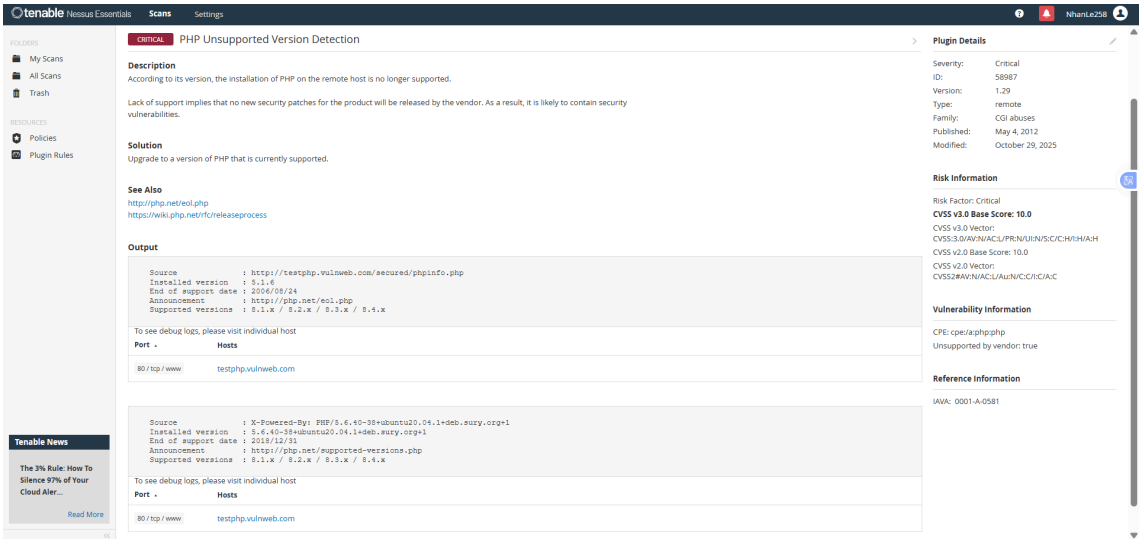


B. Sử dụng phần mềm hết vòng đời hỗ trợ (PHP Unsupported Version)

- **Mức độ:** Critical
- **Điểm CVSS: 10.0 (Mức tối đa)**

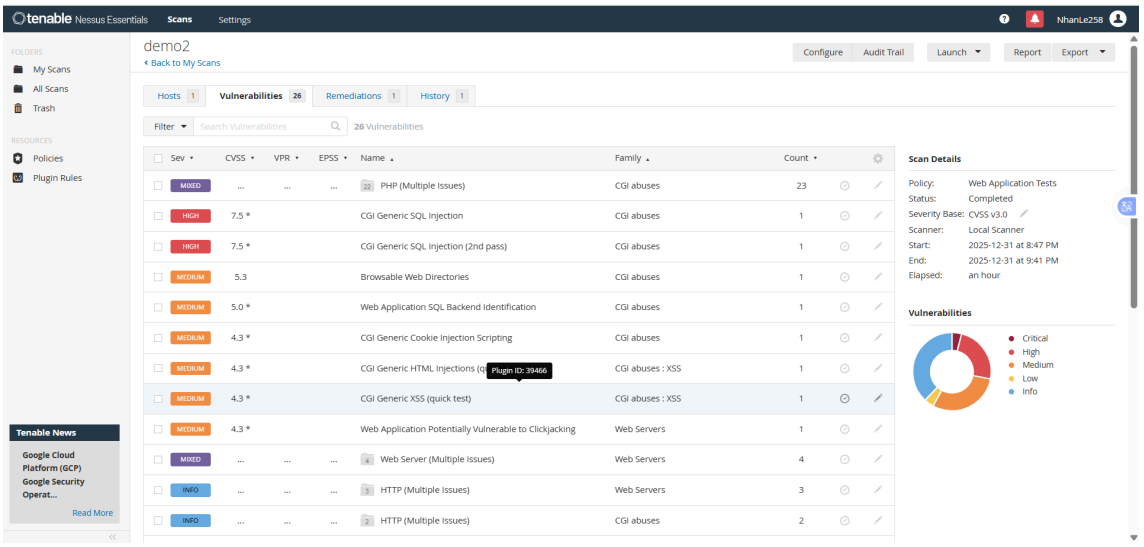


- **Mô tả kỹ thuật:** Kết quả quét định danh (Service Detection) cho thấy máy chủ đang vận hành trên một phiên bản PHP đã cũ và nhà phát triển đã ngưng hỗ trợ (End-of-Life).
- **Phân tích rủi ro:** Đây là lỗ hổng nghiêm trọng nhất. Các phiên bản phần mềm cũ chứa hàng loạt các mã lỗi (CVE) đã được công bố công khai. Hacker có thể dễ dàng tìm kiếm các công cụ khai thác tự động (Exploit Kits) trên Internet để tấn công mà không cần trình độ cao. Điểm 10.0 phản ánh việc hệ thống hoàn toàn không có khả năng tự vệ trước các cuộc tấn công đã biết.

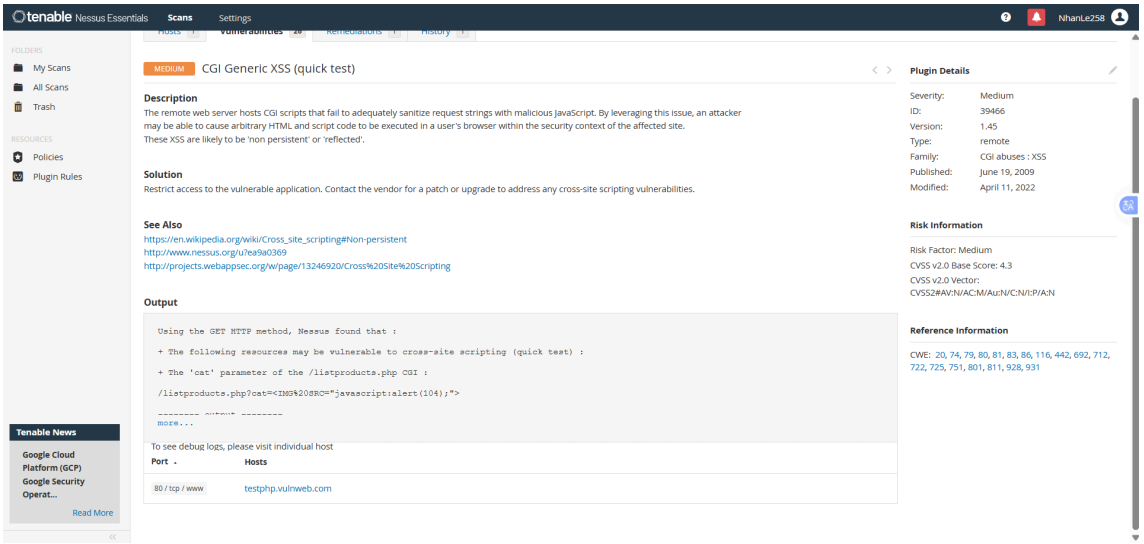


C. Lỗ hổng Cross-Site Scripting (XSS) và Duyệt thư mục (Directory Traversal)

- **Mức độ:** Medium/High (CVSS ~ 4.3 - 5.3)



- **Mô tả:** Nessus phát hiện khả năng chèn mã JavaScript độc hại vào trình duyệt người dùng (XSS) và khả năng liệt kê danh sách tệp tin trong thư mục web (Browsable Web Directories).
- **Nguy cơ:** Tuy không ảnh hưởng trực tiếp đến Server, nhưng các lỗ hổng này đe dọa trực tiếp đến người dùng cuối (mất cookie, session hijacking) và làm lộ cấu trúc mã nguồn của website.



3.4. Đánh giá và Kiến nghị (Evaluation & Recommendation)

3.4.1. Đánh giá công cụ Nessus

Qua quá trình thực nghiệm, nhóm nghiên cứu đánh giá công cụ Nessus có các ưu điểm sau:

1. **Cơ sở dữ liệu phong phú:** Nhận diện chính xác cả lỗ hổng hạ tầng (PHP version) và lỗ hổng ứng dụng (SQLi, XSS).
2. **Thông tin trực quan:** Cung cấp điểm số CVSS và phân loại màu sắc giúp quản trị viên dễ dàng ưu tiên thứ tự khắc phục.
3. **Báo cáo chi tiết:** Cung cấp không chỉ tên lỗi mà còn cả giải pháp khắc phục (Remediation) cụ thể cho từng trường hợp.

3.4.2. Kiến nghị khắc phục chi tiết cho hệ thống mục tiêu

Dựa trên báo cáo "Remediation" từ Nessus và phân tích mức độ rủi ro, nhóm đề xuất lộ trình khắc phục toàn diện như sau:

1. Khắc phục khẩn cấp (Immediate Remediations - Ưu tiên trong 24-48h)

- **Nâng cấp nền tảng (Platform Hardening):**
    - Nâng cấp PHP lên phiên bản ổn định mới nhất (ví dụ: 8.x). Việc sử dụng phiên bản EOL (End-of-Life) là nguyên nhân chính dẫn đến điểm rủi ro CVSS 10.0.
    - Cập nhật các bản vá bảo mật (Security Patches) mới nhất cho Web Server (Nginx/Apache) và Hệ quản trị cơ sở dữ liệu (MySQL).
- **Vá lỗ hổng SQL Injection:**
    - Rà soát toàn bộ mã nguồn PHP, loại bỏ hoàn toàn việc nối chuỗi trực tiếp từ người dùng vào câu lệnh SQL.

- Áp dụng bắt buộc kỹ thuật **Parameterized Queries** (Truy vấn tham số hóa) hoặc sử dụng thư viện PDO (PHP Data Objects) để tách biệt dữ liệu và mã lệnh.

2. Biện pháp phòng thủ kỹ thuật (Technical Controls - Ngắn hạn)

- **Triển khai Tường lửa ứng dụng web (WAF):**
  - Cài đặt WAF (như ModSecurity hoặc các giải pháp Cloud WAF) để lọc các lưu lượng độc hại, giúp chặn đứng các nỗ lực tấn công SQL Injection và XSS ngay cả khi mã nguồn chưa kịp sửa chữa triệt để.
- **Chống Cross-Site Scripting (XSS):**
  - Thực hiện "Context-aware Output Encoding": Mã hóa mọi dữ liệu trước khi hiển thị lên trình duyệt người dùng để vô hiệu hóa các thẻ <script>.
  - Thiết lập các tiêu đề bảo mật HTTP (Security Headers) như Content-Security-Policy (CSP) để hạn chế các nguồn tải script không xác định.
- **Cấu hình an toàn cho Web Server:**
  - Tắt tính năng Directory Listing để ngăn chặn kẻ tấn công liệt kê và xem cấu trúc thư mục của website.
  - Ẩn thông tin phiên bản (Version Disclosure) trong HTTP Header (ví dụ: Server: Nginx/1.x.x, X-Powered-By: PHP/5.x) để gây khó khăn cho quá trình trinh sát của hacker.

3. Chiến lược dài hạn và Quy trình (Process & Strategy)

- **Tích hợp bảo mật vào quy trình phát triển (DevSecOps):**
  - Sử dụng các công cụ kiểm tra bảo mật mã nguồn tĩnh (SAST) tự động trong quá trình lập trình để phát hiện sớm lỗi.
  - Đào tạo nhận thức bảo mật (Security Awareness) cho đội ngũ lập trình viên, đặc biệt là về danh sách OWASP Top 10.
- **Giám sát và Kiểm toán (Monitoring & Audit):**

- Thiết lập cơ chế ghi nhật ký (Logging) tập trung để theo dõi và cảnh báo các hành vi truy vấn bất thường vào cơ sở dữ liệu.
- Duy trì lịch quét lỗ hổng định kỳ (hàng tuần/tháng) bằng Nessus để đảm bảo hệ thống luôn được kiểm tra trước các mối đe dọa mới phát sinh.

CHƯƠNG 4: KẾT LUẬN

DANH MỤC TÀI LIỆU THAM KHẢO

1. https://www.techtarget.com/searchnetworking/definition/Nessus
2. https://en.wikipedia.org/wiki/Tenable%2C_Inc
3. https://www.tenable.com/blog/nessus-turns-10
4. https://www.techtarget.com/searchnetworking/definition/Nessus
5. https://www.cyberly.org/en/what-are-the-benefits-of-using-nessus-for-vulnerability-scanning/index.html
6. https://www.tenable.com/sites/drupal.dmz.tenablesecurity.com/files/datasheets/NessusPro-%28DS%29-EN-v4.pdf
7. https://www.cyberly.org/en/what-is-the-difference-between-nessus-essentials-and-nessus-professional/index.html
8. https://azsoft.com/zh/-product-/phan-mem/phan-mem-bao-mat/quet-lo-hong-bao-mat/phan-mem-tenable-nessus-expert-1-year-subscription/
9. https://docs.tenable.com/nessus/10_8/Content/PDF/Nessus_10_8.pdf
10. https://bknet.edu.vn/nessus-la-gi-2959.html
11. https://www.siberoloji.com/nessus-vulnerability-scanner-for-cybersecurity/

12. https://vietnetco.vn/cac-hinh-thuc-tan-cong-mang-pho-bien-hien-nay/11727.html
13. https://securitybox.vn/8563/may-tinh-nhiem-ma-doc/
14.

PHỤ LỤC